Microsoft SharePoint ToolShell Attack (2025)

Unauthenticated RCE on On-Premises Servers

Gautam Manglani | GitHub Username: GautamManglani
edX Username: gautammanglani | **Recording Date:** 27 September 2026
Incident Date: July 2025

Primary CVE: CVE-2025-53770
Related CVE: CVE-2025-53771

☁️ What is Microsoft SharePoint?

SharePoint Server

A widely used platform for enterprise intranets, document management, and collaboration.

On-Premises vs. Online

- **On-Premises:** Hosted on corporate hardware. Target of this attack.
- **SharePoint Online:** Hosted by Microsoft (M365). **Not affected.**

🏢 **Corporate Network Edge**

⬇️

🌐 **Internet-Facing SharePoint**

⬇️

📁 **Highly Sensitive Data**

A high-value target for threat actors.

🚨 The Vulnerabilities

CVE-2025-53770 (Primary)

Auth-Bypass & RCE/Deserialization
Critical vulnerability allowing unauthenticated remote code execution via deserialization in ToolShell.

CVE-2025-53771 (Related)

Path Traversal / Security Bypass
Vulnerability used to manipulate path routing and bypass standard security checks.

The Danger: These flaws combined allowed unauthenticated, external attackers to execute arbitrary system-level commands on exposed servers.

⏳ Timeline (2025)

Earlier 2025
Microsoft patches initial flaws (CVE-2025-49704/06).

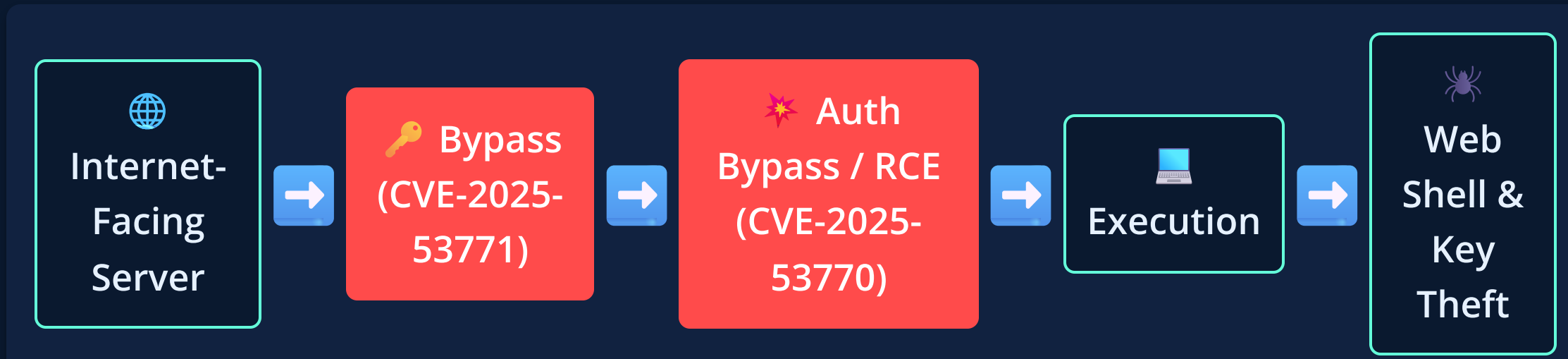
July 2025 (Exploit)
"ToolShell" bypasses initial patches in active attacks.

July 2025 (Response)
Microsoft releases urgent out-of-band updates.

Late July 2025
CISA provides mitigation guidance and adds to KEV.

CISA Action: CISA added CVE-2025-53770 to its Known Exploited Vulnerabilities catalog and provided mitigation guidance, including applying vendor security updates and configuring AMSI.

⛓️ How the ToolShell Attack Worked



1. **Locate** exposed on-premises SharePoint.
2. **Security bypass** via path traversal manipulations (CVE-2025-53771).
3. **Exploit authentication bypass and deserialization** (CVE-2025-53770).
4. **Execute** arbitrary system commands.
5. **Establish persistence** via web shells (e.g. `spinstall11`).

⚙ Technical Deep Dive

ASP.NET Insecure Deserialization

SharePoint converts formatted data (XML/JSON) back into memory objects. Without proper validation, the server acts on the attacker's malicious data, executing their code.

ASP.NET Machine Keys

Cryptographic keys used to encrypt/sign tokens. Attackers stole these to forge valid administrator session cookies.

Web Shells & PowerShell

- **Web Shell:** A malicious script (e.g., `.aspx`) dropped in the web directory.
- **PowerShell:** RCE was used to spawn `powershell.exe` as the system account, providing total control.

💥 Verified Impact

> **Exposed Attack Surface:** Thousands of on-premises servers were vulnerable due to direct internet exposure without proper Web Application Firewalls (WAF).

Confirmed Post-Exploitation

- Installation of persistent web shells (`spinstall0.aspx`).
- Theft of ASP.NET machine keys.
- Execution of PowerShell commands as the SYSTEM account.

Potential Consequences

- Lateral movement into the internal corporate network.
- Massive data exfiltration from SharePoint databases.
- Deployment of ransomware.

🗺️ MITRE ATT&CK Mapping

Tactic	Technique Used	ID
Initial Access	Exploit Public-Facing Application	T1190
Execution	Command & Scripting Interpreter (PowerShell)	T1059.001
Persistence	Server Software Component: Web Shell	T1505.003
Credential Access	Steal Application Access Token / Machine Keys	T1528
Defense Evasion	Indicator Removal on Host / Obfuscation	T1070

Key Takeaway: Attackers "lived off the land" by utilizing native web server processes and PowerShell, making their activity highly evasive.

⚠️ Why Existing Security Controls Failed

- 🌐 **Direct Internet Exposure**
  Traditional firewalls permit Port 443 (HTTPS). Without a WAF filtering paths, malicious requests pass right through.
- ⏳ **Delayed Patching**
  Vulnerability management cycles were too slow to apply the July 2025 out-of-band updates before exploitation.
- 👁️ **Monitoring Gaps**
  Standard antivirus struggles to differentiate a malicious `.aspx` web shell from legitimate web application files.
- 🛑 **Insufficient Segmentation**
  On-premises servers often bridged the DMZ directly to the internal network without isolation.

🛡️ Defensive Recommendations

1. ✅ **Apply Security Updates:** Immediately install Microsoft's July 2025 patches.
2. ✅ **Rotate Machine Keys:** If compromised, patching is insufficient. Rotate ASP.NET keys to invalidate forged tokens.
3. ✅ **Enable AMSI & EDR:** Ensure Antimalware Scan Interface is configured for SharePoint. Monitor `w3wp.exe` for PowerShell child processes.
4. ✅ **Restrict Exposure:** Do not expose admin interfaces to the public internet. Use VPNs, Reverse Proxies, and network segmentation.
5. ✅ **Hunt for Web Shells:** Actively scan web directories for unauthorized `.aspx` file creation.

📚 References & Questions

Sources & Citations

- **Microsoft Security Response Center (MSRC).** (2025, July). *CVE-2025-53770 and CVE-2025-53771 Security Update Guide.*
- **Cybersecurity and Infrastructure Security Agency (CISA).** (2025, July). *Known Exploited Vulnerabilities Catalog Update.*
- **MITRE Corporation.** (2025). *MITRE ATT&CK Framework.*
- *(High-quality security research blogs documenting the ToolShell chain, July 2025).*

Thank You. Questions?